

Data Security in the Healthcare System

Description of Topic:

History of Privacy in the Healthcare System (Berny):

The first attempt to regulate healthcare privacy came with the Privacy Act of 1974, which governed only federal health records, leaving private healthcare providers entirely unregulated. This gap ultimately led to HIPAA in 1996, which established the first comprehensive federal framework for patient privacy. HIPAA requires three covered entities (healthcare providers, insurers, and their business associates), to safeguard Protected Health Information (PHI) across 18 identifiers. However, HIPAA was built for a healthcare system where all patient data resided within traditional clinical settings. Today, third-party apps, wearable devices, telehealth sensors, and genetic testing services collect vast amounts of personal health data, yet none qualify as covered entities. These companies can collect, store, and sell patient data with little oversight, a reality most patients are unaware of.

This regulatory gap has coincided with a sharp rise in healthcare data breaches, which have tripled over the last decade. Phishing, ransomware, and denial-of-service attacks are the most common methods, and the consequences are severe. The average healthcare breach costs approximately \$8 million, with per-record costs exceeding \$400. The 2026 case of *Epic Systems v. GuardDog Telehealth*, in which GuardDog allegedly exploited healthcare systems to improperly access thousands of patient records for commercial purposes, underscores how existing regulations have failed to keep pace with an increasingly connected digital health landscape.

Research question and Summary:

Name of project: Data Security in the Healthcare System:

Q: What are the current challenges to healthcare privacy in the digital age, and what solutions are there to mitigate the risk of privacy violations of an individual's healthcare information?

Privacy in the healthcare system remains a pressing issue: healthcare information remains one of the most personal and private aspects of an individual's identity. Nevertheless, in this digitized world, there are increasing concerns as to the security of that private information. The rise of digital technologies has led to an expansion of entities involved in the healthcare system beyond those traditionally considered as part of the healthcare ecosystem. Third-party apps, digital portals, watches, and health care technology (like fall sensors) all now collect deeply personal data of an individual's healthcare identity. Some regulations, such as HIPAA, do exist, but they fail to entirely encapsulate the ever-expanding digital ecosystem that the healthcare ecosystem has decided to embrace. Misuse of healthcare data can be classified into multiple categories, including but not limited to unauthorized access, selling of data to third parties, and the use of personal data to abuse the patient.

Legal Challenges (Dimitri):

The legal challenges around data security and the healthcare system fall into two main camps: (1) the limitations of HIPAA in the context of the current healthcare ecosystem, and (2) the division between state and federal law regarding healthcare privacy.

HIPAA ensures that patient data is protected and secure. Specifically, HIPAA applies to *three main “covered entities”*: *hospitals, insurers, and their contractors*. Thus, it is these entities, which can be termed the “traditional” healthcare ecosystem, that are required by law to ensure the security and integrity of patient healthcare information. However, since 1996 and with the advent of new healthcare technologies, the healthcare system no longer operates within this traditional ecosystem: watches, apps, home sensors, and patient portals all play a major role in storing vast amounts of patient data. The fundamental legal challenge consists of the fact that HIPAA is fundamentally useless in providing regulation on these newer digitized entities: they simply fall out of the scope of HIPAA. Because of this, these entities effectively operate without regulation, and thus, patient data is often sold to data brokers and stored inappropriately.

Moreover, the division between state and federal law presents another challenge to healthcare data security. Because of the gaps in HIPAA and in the absence of additional federal regulation, the burden falls on states to create laws to regulate these newer digitized healthcare entities. For example, Washington's "My Health My Data Act" targets many of the digitized healthcare entities not under HIPAA. Though this type of regulation is a move in the right direction, the fact that such laws only exist on the state level presents severe legal challenges. That is, it leads to what is termed “data segmentation issues,” which occur because healthcare organizations operating across multiple state jurisdictions must separate data into distinct camps: those regulated solely by HIPAA and those regulated by state law. This makes for severe operational complexity, as the need to comply with multiple, often contradictory, state laws drives up legal, administrative, and technological costs.

Ethical implications (Jaeyeon):

Privacy and confidentiality in healthcare give rise to multiple ethical implications, as patient records often are linked to sensitive information regarding one's identity. As patient records often contain strictly personal information, such as immigration status, sexual orientation, and mental health history, individuals can frequently be reidentified from supposedly deidentified datasets, which further exposes them to discrimination, stigmatization, or misuse of sensitive information. While this itself goes against the right to confidentiality and anonymization of healthcare, it becomes particularly concerning for vulnerable populations with marginalized identities, who may face unequal treatment or targeted exploitation if their data are exposed.

Even beyond the risks of misuse, the mere unauthorized access or use of patient data is inherently harmful, as it violates the fundamental principle of confidentiality that underpins the patient-provider relationship. In healthcare, confidentiality is not just a legal requirement but a core moral obligation tied to patient autonomy, dignity, and trust. Thus, the nonconsensual sharing and use of patient data significantly harms patients' sense of control over their own information, violating the principle of informational privacy and, more broadly, undermining trust in the healthcare system itself.

Solutions (Lyons):

One comprehensive solution is to expand the authority of the Federal Trade Commission (FTC) to serve as the primary regulator of digital health data, particularly for third-party technologies that fall outside the scope of HIPAA. By leveraging its existing consumer protection powers, the FTC could establish standardized privacy rules through enforceable codes of conduct and safe harbor provisions, ensuring that apps, wearable devices, and telehealth platforms are held to consistent national standards for data collection, storage, and sharing. This approach would directly address the current regulatory gap by extending oversight to entities that currently operate without meaningful accountability.

Expanding the FTC's authority would also involve transforming it from a largely reactive enforcer into a proactive, specialized regulator capable of shaping the digital health landscape. Specifically, the FTC could be granted rulemaking power to redefine what constitutes protected health data beyond HIPAA's narrow scope, explicitly including data generated through third-party apps, home monitoring devices, and digital health platforms. With this authority, the FTC could mandate baseline privacy protections such as transparent and informed consent mechanisms, strict limitations on data sharing with third parties, data minimization requirements, and robust cybersecurity safeguards, all backed by meaningful penalties for noncompliance.

In addition, the FTC could implement industry-wide certification systems through codes of conduct and "safe harbor" frameworks, where companies that meet established privacy standards receive legal protections, while those that fail to comply face increased scrutiny and liability. This structure would create strong incentives for companies to adopt higher privacy standards while still allowing flexibility for technological innovation. At the same time, a centralized FTC-led approach would reduce the fragmentation caused by the current division between state and federal law, eliminating data segmentation issues and lowering compliance burdens for organizations operating across jurisdictions. Overall, this expansion would create a more unified, enforceable, and ethically grounded system of accountability that better protects patient privacy and restores trust in an increasingly complex digital healthcare ecosystem.

Annotated list of Sources:

1. Theodos K, Sittig S. Health Information Privacy Laws in the Digital Age: HIPAA Doesn't Apply. *Perspect Health Inf Manag.* 2020 Dec 7;18(Winter):11. PMID: 33633522; PMCID: PMC7883355.

Thirty years after HIPAA was signed into law, the healthcare industry struggles to keep up with the rapid advances in digital technology. The rapid increase over the last two decades of digital health data, the switch to telehealth applications after the COVID-19 pandemic, and the overall digitization of the healthcare industry all pose serious concerns and difficulties not addressed within the current legal system.

In order to understand the main issues with the healthcare system in the digital age, it is important to understand the history of the issue. The first regulations on healthcare data can be seen in the Privacy Act of 1974, which sought to regulate health records collected and maintained by the Federal Government (e.g., healthcare records for military personnel). Though the Act did provide some "best practices," private health care providers were not affected by the Act, and remained free to choose what and what not to keep private when it came to patient records. These insufficient regulations ultimately led to the Health Insurance Portability and Accountability Act of 1996 (HIPAA), which created comprehensive legal regulations guaranteeing a right to privacy for all patients.

Though HIPAA has been highly effective, it remains deeply outdated as new digital technologies arise and patients begin taking a more active stance in ensuring their health through these new digital technologies. Though HIPAA was a major victory for patient rights, it was deeply imperfect. That is, its protections are centered around "covered entities" such as healthcare providers, insurers, and their business associates. The main problem: these protections leave many groups within the "healthcare industry" unregulated, groups that have arisen because of digital technologies. At the time when HIPAA was passed, this severe limitation remained hidden, as almost all sensitive healthcare data was stored

within traditional healthcare entities. This, however, is no longer the case, as digital technologies have fundamentally changed where data is being processed and stored. At the center of this change is the fact that digital technologies have allowed individuals to take a greater role in their health. In using such digital technologies, individuals give their phone (third-party apps), watch, healthcare portals, and genetic testing companies immense amounts of healthcare data, none of which are considered “the entities” covered under HIPAA. This means that these third-party companies are collecting extremely sensitive data with little to no regulation. This sensitive data, in turn, “belongs” to these third-party companies, which means that such data can be sold to advertisers and data brokers. Importantly, there is little awareness about such issues, as many individuals automatically assume that all healthcare information is protected under HIPAA. *The central argument of this article is that the increase in digital technologies has caused the healthcare industry to expand beyond the simple clinical context. HIPAA only applies to the clinical context because it only applies to health care information within particular “entities.” Digital technologies remain outside the clinical context and are continuing to play an increasingly important role in an individual’s healthcare, and yet they remain completely unregulated when it comes to patient privacy.*

2. Susan Li, Kamalakar Surineni, Nishant Prabhakaran, Cyber-Attacks on Hospital Systems: A Narrative Review, *The American Journal of Geriatric Psychiatry: Open Science, Education, and Practice*, Volume 7, 2025, Pages 30-39, ISSN 2950-3868, <https://doi.org/10.1016/j.osep.2025.03.002>.

This article focuses on the intersection of healthcare privacy and cyberattacks. As healthcare systems continue to go paperless by employing technologies like digital health records, telehealth, and even OpenAI, healthcare systems open themselves up to increased risk of cyberattacks: the number of cyberattacks on healthcare systems has tripled in the last decade. These attacks not only threaten the privacy of individuals but also the very functionality of the healthcare system and the ability for patients to access timely and appropriate care pertinent to their health. For example, when hackers hack into patient portals and render the portal ineffective, patients are unable to access lab results, some of which may be vital to acting quickly to ensure effective treatment. Because there is very little legal regulation of these platforms, these digital technologies have little to no safeguards against hackers and malware. More than a quarter of healthcare organizations have a rating of low cybersecurity maturity, and only 3% have a rating of mature.

The most common types of attacks are phishing, malware, ransomware, and denial-of-service. The most common technique is phishing, which occurs when hackers send fraudulent messages appearing to be from a credible individual to healthcare workers in order for them to reveal patient information. Then, hackers sell patient records on the black market, which can be sold for up to \$1,000 each. Malware typically serves as a precursor to ransomware, where hackers encrypt critical patient records, rendering them unusable until payment is received. As mentioned before, this can have devastating effects on patient health. Because the medical system relies so heavily on digitized technologies, when such technologies are down or unusable, patients cannot obtain effective and timely treatment for illnesses. Denial-of-service is a similar strategy, though it uses a different technique. When hackers employ this strategy, they flood a hospital’s network with fake traffic, rendering their servers useless until the hospital pays a certain sum of money. *The main argument of this article is that there must be a two-fold change to the healthcare system in the digitized age. First, the law should seek to regulate and mandate a certain amount of digital security and malware protection that third-party health care companies must have. For example, companies that run patient portal software must guarantee their software has a certain amount of security. Next, hospitals and healthcare workers themselves should be trained in malware detection techniques.* Thus, this paper calls for a radical shift in health policy in order to ensure healthcare privacy in the digitized age.

3. Hall JL, McGraw D. For telehealth to succeed, privacy and security risks must be identified and addressed. *Health Aff (Millwood)*. 2014;33(2):216-221.

New innovative digital technologies have allowed for the extension of medical care outside traditional health care settings. These new health care technologies allow patients to take a more active role in their health through patient self-reporting and new and direct ways for patients to monitor their health. This article argues that, though there are certain benefits to telehealth technologies, such as reduced costs and increased patient satisfaction, they raise a new domain of ethical issues—most notably privacy and security risks. These risks, in turn, affect both patients' and clinicians' desire to use such platforms. The main argument of this paper is that current regulations are not enough to secure the privacy of data held by telehealth systems and that the Federal Trade Commission must be the single organization to develop and enforce privacy and security regulations.

What are some of the privacy risks that telehealth digital technologies pose? One new innovative technology is the use of “telehealth sensors,” which are sensors placed in a patient's home to detect medical emergencies such as falls. However, these technologies, in seeking to identify patient falls, also detect other household activities, many of which the patient may wish to keep private, such as substance abuse or whether or not the house is occupied at a particular time. Apps that seek to track a patient's movement, heart rate, or prescribed exercise routine also often track the patient's location. There are very few regulations that prevent these apps from sharing such information with third-party advertisers. Additionally, there are little to no regulations that mandate a certain level of encryption or data security, which, in turn, makes these apps susceptible to malware and hackers.

As mentioned in article (1) above, this paper also highlights the inadequacy of HIPAA in regulating such technologies. HIPAA only applies to “covered entities”, that is, health care providers, insurers, etc, and not to third-party devices and technologies. Interestingly, this article notes that the FDA regulates telehealth devices that qualify as “medical devices.” However, the extent of their regulation is hyper-specific: the FDA only regulates the “security” of the device and not the integrity of data privacy. That is, they ensure that the technology is working effectively; however, not that the data the technology collects is protected with integrity. Thus, this article calls for a radical solution: the Federal Trade Commission must step in to create and enforce telehealth privacy and security. The FTC has previous experience in enforcing consumer protection laws against companies violating privacy laws. One example of this is COPPA (The Children’s Online Privacy Protection Act), which mandates strict privacy protections for children under the age of 13. The paper concludes with the suggestion that the FTC should work with telehealth companies in creating privacy “codes of conduct.” If companies comply with such codes of conduct, the FTC would provide legal protection should any legal action be brought against them.

4. Institute of Medicine (US) Committee on Health Research and the Privacy of Health Information: The HIPAA Privacy Rule; Nass SJ, Levit LA, Gostin LO, editors. Beyond the HIPAA Privacy Rule: Enhancing Privacy, Improving Health Through Research. Washington (DC): National Academies Press (US); 2009. 2, The Value and Importance of Health Information Privacy. Available from: <https://www.ncbi.nlm.nih.gov/books/NBK9579/>

This article focuses on the value and importance of healthcare privacy as pertaining to individuals and society as a whole. They discuss “privacy” as a term that has no universally accepted definition. This is because privacy is experienced on a personal level and thus means different things to different people. It is also context specific. Privacy acquires a different meaning depending on the stated reasons for the information being gathered and intentions of parties involved. There is also the factor of politics, conventions, and cultural expectations.

Privacy is concerned with the collection, storage, and use of personal information, and examines whether data can be collected in the first place, as well as the justifications, if any, under which data collected for one purpose can be used for another (secondary purpose). An important issue is whether the personnel have authorized the specific uses for their personal information.

Confidentiality addresses the issue of how personal data that have been collected for one approved person may be held and used by the organization that collected the data, what other secondary or further uses may be made of the data, and when the permission of the individual is required for such uses.

Security addresses the issue of how personal data that have been collected for one approved person may be held and used by the organization that collected the data, what other secondary or further uses may be made of the data, and when the permission of the individual is required for such uses.

Protecting the privacy, confidentiality, and security of health information is essential for both ethical and practical reasons. Some view privacy as a fundamental human right tied to dignity and moral worth, while others see it as valuable because it supports autonomy, individuality, and respect. In healthcare, maintaining privacy helps prevent harm such as stigma, discrimination, and embarrassment, and encourages patients to share accurate and complete information, which is critical for quality care. Privacy also allows individuals to manage different social relationships and contributes to a free and well functioning society. In addition, strong privacy protections build trust, which supports participation in health research and improves the quality of data collected.

Public attitudes reflect both the importance and complexity of health information privacy. Many Americans remain concerned about how their medical data is used, even after regulations like HIPAA, particularly regarding unauthorized access and potential discrimination. These concerns can lead individuals to withhold information or avoid seeking care. At the same time, most people support health research if safeguards are in place, especially when data is anonymized and consent is obtained. Trust is a key factor, as people are more willing to share information when they believe it will be protected and used responsibly. Overall, strong privacy protections that emphasize security, transparency, and accountability are necessary to maintain public trust, encourage research participation, and protect both individual and societal well being.

Some recommendations that are made:

- Researchers and other data users should disclose clearly how and why personal information is being collected, used and secured, and additionally subject to obligations to ensure that personally identifiable information is used appropriately and securely.
- Appoint a security officer responsible for assessing data protection, implement solutions & staff training
- Greater encryption and other techniques for data security is needed.
- Include data security experts on IRBs
- Breach notification requirements to patients must be implemented
- Implement layers of security protection (such as two-step verification) to eliminate single points of vulnerability

5. <https://www.hhs.gov/sites/default/files/cost-analysis-of-healthcare-sector-data-breaches.pdf>

Data breaches can have a significant impact on both the healthcare organization attacked and the individual victims as well. Healthcare and Public Health Sector (HPH) sector entities face the cost of recovery, lawsuits, and the public relations ramifications including loss of customers and patients as well. The federal government has passed several pieces of legislation in order to help protect against and curb data breaches, including regulations and penalties for healthcare organizations that are non-compliant. The federal government has passed several pieces of legislation in order to help protect against and curb data breaches. There are penalties for healthcare organizations that are non-compliant. According to a Ponemon Institute study, the average cost of a breach for a healthcare organization is approximately \$8 million and trending upwards, and another study concluded that a total breach cost can exceed \$400 per patient record exposed. This is why it is so important to establish strong risk management practices.

Protected Health Information, or PHI, is defined from the Health Insurance Portability and Accountability Act of 1996 as information that uniquely identifies the individual to whom it is related. It also must be generated or received by a healthcare provider and it must be related to a patient's medical or financial information.

There are 18 PHI protected health identifiers defined by HIPAA. These include:

- Patient name Dates (birth, treatment, death)
- Physical addresses
- Fax numbers
- Social security numbers certificate/license numbers
- phone numbers
- full face photos/other pictures
- URLs/web addresses
- E-mail addresses
- health plan beneficiary information
- Internet Protocol (IP) addresses
- medical record #s
- device identifiers and serial #s
- biometric (finger, voice, etc.) info
- account numbers
- vehicle identification information
- Other uniquely identifying info

At least one study has identified the value of a PHI record at \$1000 each.

PHI can also be electronic, or Electronic PHIs (ePHI). ePHI can theoretically be stolen by anyone around the world with access to the internet (because it exists whether indirectly or directly to the public internet).

A record in the healthcare industry is information that identifies an individual and includes protected health information either in hard copy or electronic form (PHI or ePHI). Authorized access is only limited to the patient and authorized healthcare professionals in service to the patient. Any other access from any other personnel is considered a breach.

A breach is defined as the “potential or actual access and/or use of personal information by unauthorized individuals.” Breaches may occur for three reasons: cyberattack, human error, or system error.

- Cyberattack: a deliberate attempt of a malicious individual to access data which they are not authorized to have access to.
- Human error: an inadvertent mistake by any internal employee of an organization
- System error: malfunction or some other unintended means by which an information system can fail to function properly

The healthcare industry is one of the top 4 sectors that are affected by breaches. This is because data breaches in the healthcare industry impose both direct and indirect costs. Direct costs include immediate responses such as hiring forensic experts, providing credit monitoring services, and managing customer support systems. Indirect costs arise from internal investigations, communication efforts, and longer-term consequences like customer loss and reduced trust. In the United States, the average total cost of a data breach was estimated at \$7.91 million, with healthcare breaches being especially expensive due to the sensitivity and value of medical data. The cost per compromised healthcare record has steadily increased, reaching over \$400 per record, significantly higher than other industries.

The financial impact of a breach is heavily influenced by how quickly it is detected and contained. In healthcare, breaches often take months to identify and resolve, which substantially increases costs. Notification expenses alone can reach hundreds of thousands of dollars due to regulatory requirements and the scale of communication needed. Delays in detection or containment can add over \$1 million in additional costs, while faster response times significantly reduce financial damage. Beyond operational expenses, breaches also lead to reputational harm and customer loss, which can dramatically increase total costs depending on the percentage of affected users who leave.

Breaches most commonly result from cyberattacks, though human error and system failures also contribute. Malicious attacks tend to be the most expensive to resolve. Several factors determine the overall cost of a breach, including the size of the organization, the sensitivity and volume of exposed data,

and how long the data remains vulnerable. In healthcare, large-scale breaches can expose millions of records, amplifying both financial and operational consequences.

To address these risks, organizations focus on both prevention and cost mitigation. Preventive measures include strong IT security policies, data encryption, employee training, and continuous system monitoring. Tools like data loss prevention systems and incident response plans help reduce vulnerabilities and improve readiness. When breaches do occur, rapid detection, containment, and recovery are critical to minimizing damage. Investments in incident response teams, encryption, and threat intelligence sharing have been shown to significantly lower costs. Cyber insurance can also help offset financial losses, though it must be integrated into a broader risk management strategy.

6. <https://storage.courtlistener.com/recap/gov.uscourts.txnd.395990/gov.uscourts.txnd.395990.34.0.pdf>

Purl, M.D. v. United States Department of Health and Human Services

The case *Carmen Purl et al. v. U.S. Department of Health and Human Services* centers on a challenge to a 2024 federal rule that expanded HIPAA privacy protections for reproductive health care information. The rule was issued after *Dobbs v. Jackson Women's Health Organization* and aimed to prevent sensitive medical information, such as abortion-related care, from being used in investigations or legal actions against patients or providers. Dr. Carmen Purl, a Texas physician, argued that the rule conflicted with her obligations under state law, particularly requirements to report suspected child abuse and assist in public health investigations.

The court ruled in favor of the plaintiffs and found the rule unlawful under the Administrative Procedure Act. A key reason was that HIPAA explicitly prevents federal regulations from limiting state public health laws, including those governing child abuse reporting and investigations. The court determined that the 2024 rule imposed significant burdens on providers by requiring them to evaluate whether care was lawful, screen medical records for reproductive health information, and obtain detailed attestations before sharing information. Even though disclosure might still be possible, the court held that these added requirements effectively restricted compliance with state law and therefore violated HIPAA.

The court also concluded that the Department of Health and Human Services exceeded its authority by redefining important statutory terms. The rule narrowed the definition of "person" to exclude unborn children and restricted the meaning of "public health" in a way that limited how states could conduct investigations. According to the court, HHS does not have the power to make such changes, particularly when they interfere with areas traditionally regulated by the states.

In addition, the court applied the major questions doctrine, emphasizing that the rule addressed highly controversial issues such as abortion and gender-related care. Because these topics carry significant political and social importance, the court required clear authorization from Congress for an agency to regulate them. It found that HIPAA's general language about protecting health information did not provide that level of authority. As a result, the court vacated most of the rule nationwide, leaving only a small portion unrelated to the reproductive health provisions in place.

7. <https://www.hhs.gov/sites/default/files/privacysummary.pdf>
Summary of the HIPAA privacy rule by HHS.

8. Conduah, Andrew Kweku, et al. "Data Privacy in Healthcare: Global Challenges and Solutions." *Digital Health*, U.S. National Library of Medicine, 4 June 2025, [pmc.ncbi.nlm.nih.gov/articles/PMC12138216/](https://pubmed.ncbi.nlm.nih.gov/articles/PMC12138216/).

(<https://journals.sagepub.com/doi/epub/10.1177/20552076251343959>)

This paper provides an overview of the legal framework surrounding data privacy within the healthcare industry, along with an analysis of case studies regarding significant data breaches. More specifically, it analyzes major global regulations including General Data Protection Regulation (GDPR),

California Consumer Privacy Act (CCPA), Protection of Personal Information Act (POPIA), and Health Insurance Portability and Accountability Act (HIPAA). It further outlines the systemic vulnerabilities revealed through real-world examples, and the role of emerging technologies in improving data protection. The core purpose of the paper is to identify key challenges and purpose solutions for protecting sensitive data globally.

Through analyzing regional disparities in data protection, the paper effectively identifies how differences in enforcement, infrastructure, and policy design contributes to uneven privacy outcomes across North America, Europe, Asia, and sub-Saharan Africa. While North America and Europe have strong regulations (HIPAA and GDPR), their policies often suffer from weak enforcement and outdated systems. The Asia-Pacific and sub-Saharan African regions are also not exceptions to such limitations, as they frequently face challenges due to weak cross-border governance and limited infrastructure. Through this, the paper demonstrates that overall global regulations exist, but implementation gaps differ by region, and policies tend to be short-reaching even in the most developed economies.

Through such analysis, the paper argues that the primary issue in healthcare data privacy is not the absence of regulation, but rather the inconsistencies in implementation and technological capabilities. In order to address such weaknesses, it highlights the growing importance of advanced technologies, including artificial intelligence and machine learning. More specifically, such tools can be leveraged to enhance breach detection, optimize data encryption algorithms, and automate compliance monitoring. Ultimately, effective data privacy protection requires a combination of harmonized global regulations, investment in technological infrastructure, and increased international collaboration. Contrary to common belief that technological advancement inherently threatens privacy, the paper demonstrates that in an era of continuous innovation, data protection mechanisms must evolve alongside these developments, and that technology itself can serve as a powerful tool for safeguarding sensitive information.

9. Chiruvella, Varsha, et al. "Ethical Issues in Patient Data Ownership." *Interactive Journal of Medical Research*, JMIR Publications Inc., Toronto, Canada, www.i-jmr.org/2021/2/e22269. Accessed 16 Apr. 2026.

(<https://www.i-jmr.org/2021/2/e22269> <https://pmc.ncbi.nlm.nih.gov/articles/PMC8178732/>)

This paper dives into the issue of patient privacy within the health care industry, and analyzes the ethical considerations regarding data storage and usage. More specifically, it raises concerns regarding the sharing of patient data with for-profit entities that seek to exploit such information for commercial gain, and explores how these practices intersect with broader ethical and civil rights concerns.

The paper starts off by analyzing the history of patient recording and the gradual emergence of data breach problems within data systems. While patient case records had mainly been stored in written form in its initial stages, the recent trend towards automation rapidly gave rise to digital recordings such as Electronic Health Record (EHR) and Electronic Medical Record (EMR). Such digitalizations, despite their convenience, were accompanied with severe concerns towards patient privacy, as data breaches have become much easier within systems. Thus, the paper clearly suggests that,

"A balance between upholding patient privacy, autonomy, and furthering medical knowledge through research and providing efficient, beneficial patient care, as outlined in the principle of beneficence, has become an increasingly important topic because of the rise of advanced technology integration into medical practice"

Along with the digitalization trend in patient data storage systems, the growing involvement of technology companies have also given risk to new risks to patient privacy. The paper maintains that large tech companies have been purchasing patient data for commercial exploitation, which leads to further dangers of hacking and unauthorized data collection. In particular, the paper provides a case study of Amazon, who purchased and utilized

patient data to develop new drugs, devices, and algorithms. As such, data sharing with third-party and commercial entities have risen as significant contemporary concerns, with regulatory frameworks such as the HIPAA falling short to effectively address them.

Such ethical concerns are further exacerbated as third parties increasingly target vulnerable populations through data breaches. One example includes agencies potentially monitoring sensitive demographic data such as transgender demographics and immigration statuses for non-health purposes. Due to the sensitive nature of such data, its misuse can lead to the denial of justice, equality, and fairness for vulnerable populations, making the protection of patient information an increasingly significant ethical dilemma that requires careful consideration.

10. *Stipulation re: Judgment and Permanent Injunction, Epic Systems Corp. et al. v. Health Gorilla, Inc. et al.*, No. 2:26-cv-00321 (C.D. Cal. Mar. 13, 2026)
(<https://www.epic.com/content/stipulation-re-judgment-and-permanent-injunction.pdf>)

This legal document outlines a stipulated judgment and permanent injunction resolving claims brought by major healthcare organizations, including Epic Systems and Trinity Health, against GuardDog Telehealth and associated entities. The case centers on allegations that GuardDog improperly accessed thousands of patient medical records through the Carequality interoperability framework by falsely representing that such access was for treatment purposes. In reality, the records were obtained, reviewed, and distributed to law firms for non-clinical, commercial uses. The document details how GuardDog leveraged third-party access points and regulatory ambiguities to obtain sensitive patient data without proper authorization, raising serious concerns about misuse of healthcare interoperability systems.

As part of the settlement, GuardDog agreed to a permanent injunction prohibiting further access to such data systems and requiring the deletion of all improperly obtained patient records. The case highlights significant vulnerabilities in healthcare data-sharing frameworks, particularly the potential for actors to exploit systems designed for legitimate medical use.

This source is valuable for research on healthcare data privacy because it provides a concrete, real-world example of how regulatory gaps and technological infrastructures can be manipulated for unauthorized data access and commercial gain. It supports broader arguments regarding the limitations of current privacy protections, the risks associated with third-party access to health data, and the need for stricter oversight and enforcement mechanisms in digital healthcare systems.